ScamShield AI

Product & Technical Requirements Document (PRD & TRD)

Version 2.1.0 · Official Cybersecurity Specification

Generated: 10/15/2026

Executive Summary

ScamShield AI is an enterprise-grade, privacy-first cybersecurity platform that protects users before they click malicious links or surrender credentials.

Key Capabilities:

• Trilingual inspection supporting English, Urdu, and Roman Urdu dialect phonetics.
• Zero-outbound SSRF isolation guaranteeing 100% safe client and server operation.
• Real-time public blacklist querying against Abuse.ch URLhaus, OpenPhish, and Spamhaus.
• Multimodal screenshot vision radar powered by Google Gemini 3.8 Flash.
• Tactile Claymorphism design system calibrated for desktop and mobile viewports.
• Complete GDPR compliance with 1-click JSON data export and irreversible hard purge.

Table of Contents

1. Section 1: Product Requirements Document (PRD)
2. Section 2: Target User Personas & Problem Scenarios
3. Section 3: Technical Requirements Document (TRD)
4. Section 4: Zero-Outbound SSRF Architecture
5. Section 5: Real-Time Public Blacklist Pipeline
6. Section 6: API Endpoints Contract (/api/v1)
7. Section 7: Relational Database Schema & PostgreSQL Model
8. Section 8: Threat Flowcharts & Multilingual Matrices

Section 1: Product Requirements Document (PRD)

1.1 Product Vision & Core Mission

ScamShield AI operates on the core principle "Think Before You Click". By intercepting social engineering attempts within private peer-to-peer messaging networks (WhatsApp, SMS, Telegram), it prevents financial theft, account takeover, and identity fraud before harm occurs.

1.2 Target User Personas

Persona A: Everyday Mobile Banking User ("Ayesha", 32)

Needs instant 5-second check when receiving SMS claims that her bank account or mobile wallet (EasyPaisa/JazzCash) is suspended. Requires simple, unequivocal green/red advice.

Persona B: Senior Citizen / Regional Speaker ("Haji Sahab", 65)

Receives fraudulent BISP poverty relief or fake lottery claims in Roman Urdu. Requires high-contrast legible visual cues and clear warnings in his native dialect.

Persona C: Tier-1 SOC / Security Analyst ("Farhan", 28)

Needs structural URL dissection, punycode lookalike detection, MITRE ATT&CK technique tags, and public blacklist verification status without risking outbound requests to attacker servers.

Section 2: Technical Requirements Document (TRD)

2.1 Zero-Outbound SSRF Isolation Security Model

Server-Side Request Forgery (SSRF) represents a critical flaw in legacy online scanners. Attackers submit cloud metadata endpoints (e.g., http://169.254.169.254) or internal loopback IP addresses (http://127.0.0.1) to trick the scanner into exfiltrating credentials. ScamShield completely mitigates this threat:

```
// server/analysis/urlInspector.ts — Zero-Outbound Defense

1. Never executes HTTP GET / HEAD requests to target destinations.

2. Inspects URL RFC grammar strictly in memory (lexical evaluation).

3. Private IP ranges (RFC 1918 & Cloud Metadata) flagged immediately.

4. Outbound queries dispatch ONLY to verified public blacklist feeds (URLhaus).
```

2.2 Real-Time Public Blacklists Architecture

Before presenting results, ScamShield queries suspicious hostnames in parallel against open feeds:
• Abuse.ch URLhaus (Active Malware & Payload URLs)
• OpenPhish Community Intelligence (Zero-Day Phishing)
• Spamhaus Domain Blocklist (DBL) & SURBL
• ThreatFox IoC Engine (Command and Control Infrastructure)
Orchestrated with 2.5s AbortController timeouts and in-memory LRU caching (15-min TTL).

Section 3: API Specification & Relational Models

3.1 Core API Contracts (/api/v1)

POST	**`/api/v1/analyses`**	Submit text, URL, or screenshot for security inspection
GET	**`/api/v1/analyses`**	Paginated search and history filter with risk tags
GET	**`/api/v1/analyses/:id`**	Retrieve full analysis audit record and blacklist details
DELETE	**`/api/v1/analyses/:id`**	Delete individual scan record (ownership enforced)
DELETE	**`/api/v1/analyses`**	Hard purge all user records (GDPR Right to Be Forgotten)
POST	**`/api/v1/reputation/check`**	On-demand real-time public blacklist reputation lookup
GET	**`/api/v1/account/export`**	Instant JSON data export (GDPR Data Portability)